

GSG-04

90-Day Action Plan

Practical Security in Three 30-Day Stages

A step-by-step plan that tells you exactly what to do, in what order, to meaningfully improve your business security — without needing a dedicated IT team or a large budget.

Days 1-30

Foundation

Days 31-60

Build

Days 61-90

Sustain

HOW TO USE THIS PLAN

This plan is organized into three 30-day stages. Each stage builds on the last — start with Stage 1 before moving to Stage 2. Assign a name to the "Who" column for each action so someone is responsible. Check the box when it is done.

If you have completed the Green Security Group Security Assessment, use your lowest-scoring areas to decide which actions to tackle first within each stage.

STAGE 1

Foundation

Days 1-30

Stage 1 covers the actions with the biggest impact for the least effort. These are the basics — and they prevent the majority of small business security incidents. Complete all of Stage 1 before moving on.

#	Action	Who	Done
1	Turn on two-step verification for all business email accounts (Microsoft 365 or Google Workspace) — Owner / IT	Owner / IT	☐
2	Turn on two-step verification for all other cloud services — accounting, CRM, file storage, and any other platforms used for work — Owner / IT	Owner / IT	☐
3	Set up a business password manager (Bitwarden Teams recommended) and invite all staff	Owner / IT	☐
4	Audit all user accounts — identify any shared logins and replace them with individual accounts	Owner / IT	☐
5	Check that automatic updates are turned on for all business computers and laptops	IT Provider	☐
6	Confirm that up-to-date security software is installed and active on all business devices	IT Provider	☐
7	Change the default admin passwords on your routers, switches, and Wi-Fi access points	IT Provider	☐
8	Set up a separate Wi-Fi network for customers or guests — keep it off your business network	IT Provider	☐
9	Confirm that your business data is being backed up regularly, with at least one copy stored off-site or in the cloud	Owner / IT	☐
10	Distribute the Acceptable Use Policy (GSG-03) to all staff and collect signed acknowledgments	Owner	☐

STAGE 2

Build

Days 31-60

Stage 2 formalizes the protections from Stage 1 and addresses the gaps most likely to cause problems in an audit, an insurance claim, or a real incident.

#	Action	Who	Done
1	Distribute the Password Policy (GSG-03) to all staff and collect signed acknowledgments	Owner	☐
2	Make a list of all sensitive information your business holds — client records, financial data, health information — and where it is stored	Owner	☐
3	Verify that laptops and computers have encryption turned on (BitLocker on Windows, FileVault on Mac)	IT Provider	☐
4	Confirm that your website uses HTTPS and that any web forms handling client data are secure	IT Provider	☐
5	Make a list of all outside vendors and software tools that can access your business systems or client data	Owner	☐
6	Review and clean up any unused remote access accounts or old firewall rules	IT Provider	☐

7	Create a security checklist for when new staff join and when staff leave — to make sure nothing gets missed	Owner	☐
8	Run a 30-minute security awareness session with all staff covering how to spot a suspicious email	Owner	☐
9	Walk through the Incident Response Plan (GSG-03) as a team — what would we do if this happened?	Owner	☐
10	Complete the GSG-02 Security Review Checklist and use your scores to update your priorities	Owner	☐
11	Get quotes for cyber liability insurance from at least two providers	Owner	☐

STAGE 3

Sustain

Days 61-90

Stage 3 turns the improvements from Stages 1 and 2 into ongoing habits — so your security does not slip back over time.

#	Action	Who	Done
1	Put all Stage 1 and Stage 2 actions on a recurring annual calendar reminder	Owner	☐
2	Run a practice phishing test — send a realistic fake phishing email to staff and see who clicks	Owner / IT	☐
3	Do a full patch check — confirm all computers, software, and network equipment are fully up to date	IT Provider	☐
4	Review vendor contracts and flag any that are missing security or data protection clauses for renewal	Owner	☐
5	Write or update your data retention policy — how long do you keep different types of records, and how do you dispose of them?	Owner	☐
6	Set a monthly calendar reminder to review your network logs for anything unusual	Owner / IT	☐
7	Set a quarterly calendar reminder to review who has access to what and remove anything no longer needed	Owner	☐
8	Add security awareness training to the onboarding process for all new hires	Owner	☐
9	Brief your leadership team or board on your current security posture using the Security Review Checklist results	Owner	☐
10	Complete the Green Security Group Assessment again to measure your improvement	Owner	☐

KEEPING IT UP AFTER 90 DAYS

When	What to do
Monthly	Check network and access logs for anything unusual. Verify patches are current.
Quarterly	Test backup restoration. Review vendor access. Update user access lists.
Annually	Repeat the Security Assessment. Update policies. Run a phishing test and a practice incident exercise. Review cyber insurance.
When someone joins	Complete the security onboarding checklist. Set up accounts. Collect policy acknowledgments.
When someone leaves	Disable accounts immediately. Revoke all access. Recover business devices.

ABOUT THIS DOCUMENT

Developed with assistance from Claude (Anthropic) and reviewed by Paul Green, CISSP.